

Discovery Executive Summary

Project: disocvery-test · Generated: 27/08/2026, 11:57:35

EXECUTIVE SUMMARY

This report consolidates the overall ratings, key findings, and recommended actions from the 4 discovery analyses run across this codebase (frontend and backend). Each section below reproduces that analysis's executive view; full evidence and diagrams live in the individual reports.

Portfolio Overview

#	Analysis	Overall Rating
1	Architecture & Design Analysis	—
2	Code Quality & Complexity Analysis	—
3	Frontend Modernization Analysis	—
4	Backend Modernization Analysis	—

1. Architecture & Design Analysis

EXECUTIVE SUMMARY

The `php-admin-panel` repository is an intentionally minimal PHP admin dashboard starter template comprising 4 PHP files and approximately 300 lines of code total. The codebase uses flat, file-based PHP routing with no framework, no ORM, no database, and no authentication system — all layers that would need to exist before this template can support a real admin backend. The two most severe architectural gaps are the complete absence of any authentication or session-management mechanism (H10, High Risk) and a dashboard populated entirely with hardcoded static placeholder values with no data-binding or persistence layer (H11, High Risk). A secondary concern is `header.php` conflating navigation configuration, active-state resolution logic, and the full HTML layout in a single 185-line include — the seed of a god-file anti-pattern that will worsen as the project grows. Most classical hotspots (H1–H9) score Good only because the features that would trigger them (database, ORM, classes, domain packages) do not yet exist; the dominant architectural risk is that this template will be extended ad hoc rather than along any layered pattern, locking in the structural deficits as the codebase grows.

§1.1 Benchmark Ratings Summary

Layers covered: **Backend** — 4 PHP files (header.php 185 LOC, footer.php 46 LOC, index.php 63 LOC, profile.php 6 LOC); **Frontend** — PHP-rendered HTML templates + embedded JavaScript in footer.php (no SPA, no JS framework; all libraries from CDN). Total source: ~300 LOC.

#	Hotspot	Primary KPI	Good	Moderate	High Risk	Measured	Rating
H1	Fat Controllers	Avg LOC per PHP page/handler	<150	150–300	>300	~75 LOC avg (max: header.php 185 LOC)	Good
H2	Missing Service Layer	Files with embedded business logic	<10	10–20	>20	1 (header.php:2–42)	Good
H3	Missing Repository Pattern	Direct DB/ORM access points	<10	10–20	>20	0 (no DB)	Good
H4	Circular Dependencies	Dependency cycles	0	1–3	>3	0	Good
H5	Shared Utility Abuse	Utility files w/ business logic	0	1–5	>5	0	Good
H6	Direct SQL in Controllers	ORM compliance %	>90%	60–90%	<60%	100% (no SQL)	Good
H7	God Classes	Files >1000 LOC	0	1–3	>3	0	Good
H8	Domain Boundary Violations	Cross-domain access points	0	1–5	>5	0	Good
H9	Shared Database Coupling	Tables shared across domains	<10%	10–30%	>30%	0% (no DB)	Good
F1	Business Logic in Components	Avg LOC per PHP template component	<150	150–300	>300	~75 LOC avg	Good

F2	Missing Frontend Service/Data Layer	Template files with inline API calls	<10	10–20	>20	0	Good
F3	God / Oversized Components	PHP template files >400 LOC	0	1–3	>3	0	Good
F4	Prop Drilling / Global State Abuse	Max PHP global propagation depth	≤2	3–4	>4	1 level	Good
F5	Legacy / Inconsistent Component Patterns	Files with inline event patterns	0	1–10	>10	2 (header.php:170 <code>onclick</code> , footer.php inline <code><script></code>)	Moderate
H10	Missing Authentication System (additional)	Auth mechanisms present	Present	Partial	None	None — no <code>session_start()</code> , no <code>login.php</code> , <code>/logout/</code> missing	High Risk
H11	Hardcoded Static Dashboard Data (additional)	% dashboard widgets dynamically bound	>90%	50–90%	<50%	0% — all 4 KPI cards are literal integers; username hardcoded in header.php:139	High Risk

§1.4 Actions Required

Hotspot	Action	Rating	Priority
H10 — Missing Authentication System	Create <code>auth.php</code> (session_start + requireAuth guard), <code>login.php</code> + <code>login_action.php</code> , and <code>logout.php</code> (session_destroy + redirect); prepend <code>requireAuth()</code> to index.php and profile.php; use <code>password_hash</code> / <code>password_verify</code> ; add CSRF token to login form	High Risk	Critical
H11 — Hardcoded Static Dashboard Data	Create <code>src/Database.php</code> (PDO wrapper) and <code>src/DashboardService.php</code> ; replace the four literal KPI integers in index.php with <code>DashboardService::getStats()</code> values; replace hardcoded username in header.php:139 with <code>\$_SESSION['user_name']</code>	High Risk	High
F5 — Legacy / Inconsistent Component Patterns	Move <code>logout()</code> from footer.php:15–40 to <code>src/js/app.js</code> ; replace <code>onclick="\logout()\\"</code> in header.php:170 with <code>data-action="\logout\\"</code> + <code>addEventListener</code> ; add <code><script src=\\".src/js/app.js\\" defer></script></code> in header.php; enforce CSP in <code>.htaccess</code>	Moderate	Medium

§1.5 Expected Outcomes

- **Secure access control:** Implementing the auth layer (Phase 1) closes the most critical gap — every page becomes protected, the logout flow becomes functional, and the template is safe to extend with real admin features without accidentally exposing them publicly.
- **Live dashboard data:** Introducing the Database and Service layers (Phases 2–3) replaces the four hardcoded KPI cards with real queries and establishes the data-binding pattern all future pages should follow, eliminating inline SQL as the default extension strategy.
- **Testable business logic:** Once logic moves from header.php and inline HTML into named PHP service classes, individual functions can be unit-tested in isolation without booting an HTTP server.
- **Stricter frontend hygiene:** Externalising the logout script and removing inline `onclick` attributes (Phase 4) enables a Content Security Policy that prevents XSS from injected inline scripts — critical for an admin interface.
- **Clear extension path:** The layered template pattern (thin page → service → repository → PDO) gives contributors an unambiguous pattern to follow when adding new admin pages, preventing raw SQL from ending up directly in future PHP files.

Report saved to `docs/discovery/01-architecture-design.md` . Pipeline artifact saved to `agent-runs/20260827T114559_whbojq/01-architecture-design.md` . The PDF will be generated automatically by the orchestration UI from the Markdown file..{"stop_reason":"end_turn","session_id":"44291f3d-091b-42ba-9bae-ea673d793e18","total_cost_usd":0.9395155,"usage":{"input_tokens":14,"cache_creation_input_tokens":54213,"cache_read_input_tokens":645085,"output_tokens":27313,"server_tool_use":{"web_search_requests":0,"web_fetch_requests":0},"service_tier":"standard","cache_creation":{"ephemeral_1h_input_tokens":54213,"ephemeral_5m_input_tokens":0},"inference_geo":{"not_available"},"iterations":{"input_tokens":1,"output_tokens":2221,"cache_read_input_tokens":74995,"cache_creation_input_tokens":793,"cache_creation":{"ephemeral_5m_input_tokens":0,"ephemeral_1h_input_tokens":793},"type":"message"},"speed":{"standard"},"modelUsage":{"claude-haiku-4-5-20251001":{"inputTokens":10895,"outputTokens":16,"cacheReadInputTokens":0,"cacheCreationInputTokens":0,"webSearchRequests":0,"costUSD":0.010975,"contextWindow":200000,"maxOutputTokens":32000},"c-sonnet-4-6":{"inputTokens":14,"outputTokens":27313,"cacheReadInputTokens":645085,"cacheCreationInputTokens":54213,"webSearchRequests":0,"costUSD":0.9285405,"contextWindow":200000,"maxOutputToker":{},"terminal_reason":"completed","fast_mode_state":"off","uuid":"bccd9feb-4f7e-4dec-8eec-f55462b85329"}}

2. Code Quality & Complexity Analysis

EXECUTIVE SUMMARY

The `php-admin-panel` repository is a minimal, single-developer PHP admin scaffold totalling 300 source lines across four PHP files — no OOP classes, no dedicated service or controller layer, and no SPA frontend framework. The codebase scores well on cyclomatic complexity (max CC ≈ 8), file/function size, churn, and defect density. The primary code-quality concern is **structural duplication**: four nearly identical dashboard-card HTML blocks in `index.php` are hard-coded with static values rather than being driven by a data array and a reusable rendering helper. A secondary concern is the **mixed-concerns design** of `header.php`, which conflates PHP application logic (menu configuration, active-page detection, breadcrumb

generation) with full HTML rendering in a single flat script. Git history spans February 2025 to July 2026, covers 52 commits from a single author, and contains no defect-fix commits. All churn, defect, and ownership signals are in the Good band; the duplicate code and architectural patterns push the overall rating to Moderate.

§2.1 Benchmark Ratings Summary

#	Hotspot	Primary KPI	Good	Moderate	High Risk	Measured	Rating
H1	High Cyclomatic Complexity	Max complexity per method	<10	10–20	>20	CC = 8 (header.php — 7 branch points)	Good
H2	Large Classes	Largest class/file LOC	<300	300–1000	>1000	185 LOC (header.php) — no OOP classes	Good
H3	Large Functions	Largest function LOC	<50	50–200	>200	20 LOC (logout() in footer.php)	Good
H4	Business Logic Duplication	Duplicated business logic %	<5%	5–10%	>10%	~0% — all data is static	Good
H5	Duplicate Code (general)	Overall duplicate code %	<5%	5–10%	>10%	~8.5% (24 structural duplicate lines / 281 non-blank LOC)	Moderate
H6	High Churn Areas	Monthly changes (top files)	<5	5–10	>10	0 changes/month (last 6 months)	Good
H7	Defect-Prone Files	Fix commits (hottest file)	1–3	4–5	>5	0 fix/bug commits in 52-commit history	Good
H8	Ownership Issues	Top-author ownership %	>80%	60–80%	<60%	100% (iqbolshoh — sole contributor)	Good
H9	Magic Numbers/Strings (additional)	Static hard-coded metric values	0	1–3	>3	4 static values in index.php	Moderate
H10	Mixed Concerns (additional)	Files conflating logic + presentation	0	1	>2	1 file — header.php	Moderate
H11	Stub / Dead Code (additional)	Unimplemented pages navigable by users	0	1	>1	1 stub — profile.php	Moderate

Hotspot Score breakdown

Component	Weight	Sub-score (0–100)	Weighted
Cyclomatic Complexity	25%	25	6.25
Code Churn	25%	5	1.25
Defect Density	20%	5	1.00
Class/Function Size	15%	10	1.50
Business Logic Duplication	10%	40	4.00
Developer Ownership Risk	5%	15	0.75
Hotspot Score	100%		15 / 100

§2.5 Actions Required

Hotspot	Action	Rating	Priority
H5 — Duplicate Code (4x card scaffold in index.php)	Define <code>\$stats</code> array + <code>renderStatCard()</code> PHP helper; replace all four hard-coded card blocks with a single <code>foreach</code> loop	Moderate	Medium
H9 — Magic Numbers in index.php	Replace static literals (150, 53, 44, 65) with named PHP constants or database-sourced variables via a <code>DashboardStatsService</code>	Moderate	Medium
H10 — Mixed Concerns in header.php	Split into <code>config/menu.php</code> (data), <code>includes/page_context.php</code> (logic), <code>layout/header.html.php</code> (template)	Moderate	Medium
H11 — Stub profile.php	Implement profile content or add a visible placeholder notice and remove the sidebar nav link until the page is delivered	Moderate	Low

§2.6 Expected Outcomes

- **Lower maintenance cost:** Extracting `renderStatCard()` and a `$stats` data array reduces dashboard card changes to a single data-row edit rather than four separate HTML blocks, eliminating copy-paste drift as the metric count grows.
- **Easier testing and reasoning:** Separating `includes/page_context.php` from HTML output allows the breadcrumb and active-page detection logic to be unit-tested in isolation without bootstrapping a full HTTP response.
- **Safer evolution:** Splitting `header.php` into config, logic, and layout layers means changes to menu structure, CDN versions, or active-page detection no longer risk breaking each other — each concern has a single, predictable locus of change.
- **Honest feature status:** Resolving the `profile.php` stub removes a navigable dead-end from the sidebar, preventing user confusion and ensuring the delivered feature surface matches the navigation map.
- **Better git hygiene:** Adopting descriptive commit messages (replacing the blanket "commit") will enable future churn and defect-attribution analysis, reducing blind spots in code-quality monitoring as the codebase grows.

The full report — including §2.2 hotspot evidence with code excerpts, `affected-files` directives, and §2.4 Mermaid diagrams — has been saved to `docs/discovery/02-code-quality-complexity.md`. The orchestration UI will convert it to PDF automatically.

```

{"stop_reason":"end_turn","session_id":"8a14cf79-6d01-4018-985a-d957e98b8242","total_cost_usd":1.0988626,"usage":{"input_tokens":25,"cache_creation_input_tokens":54643,"cache_read_input_tokens":1213222,"output_tokens":26503,"server_tool_use":{"web_search_requests":0,"web_fetch_requests":0},"service_tier":"standard","cache_creation":{"ephemeral_1h_input_tokens":54643,"ephemeral_5m_input_tokens":0},"inference_geo":"not_available","iterations":{"input_tokens":1,"output_tokens":2353,"cache_read_input_tokens":75424,"cache_creation_input_tokens":794,"cache_creation":{"ephemeral_5m_input_tokens":0,"ephemeral_1h_input_tokens":794},"type":"message"},"speed":"standard"},"modelUsage":{"claude-haiku-4-5-20251001":{"inputTokens":9353,"outputTokens":13,"cacheReadInputTokens":0,"cacheCreationInputTokens":0,"webSearchRequests":0,"costUSD":0.009418000000000001,"contextWindow":200000,"maxOutputTokens":4096,"sonnet-4-6":{"inputTokens":25,"outputTokens":26503,"cacheReadInputTokens":1213222,"cacheCreationInputTokens":54643,"webSearchRequests":0,"costUSD":1.0894446000000002,"contextWindow":200000,"maxOutputTokens":4096,"terminal_reason":"completed","fast_mode_state":"off","uuid":"bfd3c8b1-21d8-4040-b8ef-105024bfd241"}}}
```

3. Frontend Modernization Analysis

EXECUTIVE SUMMARY

The `php-admin-panel` repository is a minimal PHP server-rendered admin dashboard template composed of just four view files (`header.php`, `footer.php`, `index.php`, `profile.php`) and a static assets directory. No modern JavaScript framework (React, Vue, Angular, Svelte) or build toolchain is present; the frontend is built on PHP includes, Bootstrap 5, AdminLTE 3, and jQuery loaded entirely from third-party CDNs. The most severe gaps are a complete absence of authentication guards (any visitor can reach any page by URL), five unescaped PHP echo statements that introduce XSS risk, and nine external CDN resources loaded without Subresource Integrity (SRI) attributes. The architecture is a flat root-level set of files with no feature boundaries, no reusable UI component library, no ESLint or TypeScript tooling, and no browser-compatibility configuration — which is expected for a starter template but leaves significant work before the codebase is production-ready. The overall codebase rating is **High Risk**, driven primarily by missing authentication, security vulnerabilities, lack of code-quality tooling, and an absent design/component architecture suitable for scaling.

§3.1 Benchmark Ratings Summary

#	Hotspot	Primary KPI	Good	Moderate	High Risk	Measured	Rating
H1	UI Component Duplication	Duplicate components %	<5%	5–10%	>10%	4 near-identical stat-card blocks; no reusable PHP partial	Moderate
H2	Legacy Class-Based / Imperative Components	Modern component adoption %	>90%	70–90%	<70%	0% — all 4 view files are PHP imperative templates + jQuery	High Risk
H3	Massive Components	Largest component LOC	<200	200–500	>500	185 LOC (header.php)	Good
H4	Global State Dependencies	Components reading global state %	<30%	30–60%	>60%	100% — all pages include header.php which sets/reads PHP globals	High Risk
H5	Complex State Management	Max prop-drilling depth	<3	3–5	>5	N/A — server-rendered PHP; no client-side prop-drilling	Good
H6	Weak Frontend Architecture	Feature modules with clean boundaries %	>80%	50–80%	<50%	<10% — flat root; header.php mixes routing config, head, navbar, sidebar, opening wrappers	High Risk
H7	Missing Component Inventory	Shared component % of total	>30%	15–30%	<15%	0 reusable UI components	High Risk
H8	No Design System	Inline-style / magic-value occurrences	0–5	6–20	>20	2 (header.php:107, index.php:22)	Good
H9	Routing Structure Weakness	Protected routes with guards %	100%	80–99%	<80%	0% — both pages accessible without any auth check	High Risk

							Risk
H10	No API Integration Layer	API calls in service layer %	>90%	70–90%	<70%	N/A — no AJAX or fetch calls; entirely server-rendered	Good
H11	Poor Data Caching	Data-fetching points with caching %	>70%	40–70%	<40%	N/A — no client-side data fetching	Good
H12	Weak Frontend Auth	Token storage + routes guarded	httpOnly + 100%	One gap	Both gaps	No token storage + 0% guarded pages — both gaps	High Risk
H13	Frontend Security Vulnerabilities	XSS-risk + hardcoded secrets count	0 each	1–3 total	>3 total	5 unescaped PHP echo outputs + 9 CDN without SRI = 14 total	High Risk
H14	Frontend Performance Gaps	Initial JS bundle size (gzipped)	<250KB	250–500KB	>500KB	9 CDN requests; 4 blocking scripts; duplicate SweetAlert2; no lazy-loading; >500KB total	High Risk
H15	Browser & Runtime Compatibility Gaps	Browserslist + polyfills configured	Both present	One missing	Both missing	Both missing — no .browserslistrc, no build toolchain, no polyfills	High Risk
H16	Frontend Code Quality	ESLint in CI + TypeScript strict	Both Yes	One Yes	Both No	Both No — no ESLint, no tsconfig.json, no CI pipeline	High Risk
H17	Technical Debt & Outdated Dependencies	Critical/High CVEs found	0	1–3	>3	CDN versions current; no npm audit possible; no known critical CVEs	Good
H18	Accessibility Gaps (additional)	Keyboard-navigable interactive elements %	>90%	70–90%	<70%	<code>href="javascript:void(0);\"</code> on logout; <code>onclick</code> on <code></code> ; 7 placeholder <code>href="#\"</code> links; no ARIA labels on icon-only links	Moderate

§3.4 Actions Required

Hotspot	Action	Rating	Priority
H9 — Routing Structure Weakness	Add <code>requireAuth()</code> to every protected page; implement server-side <code>logout.php</code> with <code>session_destroy()</code>	High Risk	Critical
H12 — Weak Frontend Auth	Implement login flow with <code>session_start()</code> + httpOnly cookies; enforce session check before every page render	High Risk	Critical
H13 — Frontend Security Vulnerabilities	Wrap all 5 unescaped <code><?= \$var ?></code> with <code>htmlspecialchars()</code> ; add SRI <code>integrity</code> to all 9 CDN resources; add Content-Security-Policy header	High Risk	Critical
H2 — Legacy Imperative Architecture	Introduce PHP templating engine (Blade/Twig) with layout inheritance; separate PHP routing logic from HTML template output	High Risk	High
H4 — Global State Dependencies	Replace implicit PHP globals written by header.php with an explicit <code>\$layoutData</code> array contract	High Risk	High
H6 — Weak Frontend Architecture	Reorganize into <code>layouts/</code> , <code>partials/</code> , <code>pages/</code> , <code>lib/</code> directories; close all HTML elements within the file that opens them	High Risk	High
H7 — Missing Component Inventory	Create <code>partials/</code> and <code>components/</code> directories; extract sidebar, navbar, and stat-card into named PHP partials/functions	High Risk	High
H14 — Frontend Performance Gaps	Add <code>defer</code> to all CDN script tags; remove duplicate SweetAlert2 include; add <code>loading="lazy"</code> to images; evaluate Vite/webpack for bundling	High Risk	High
H16 — Frontend Code Quality	Add <code>phpcs</code> + <code>phpstan</code> ; introduce <code>package.json</code> + ESLint with <code>eslint-plugin-html</code> ; create GitHub Actions CI workflow	High Risk	High
H15 — Browser Compatibility Gaps	Add <code>.browserslistrc</code> ; introduce <code>package.json</code> with Autoprefixer + PostCSS; document minimum supported browser targets	High Risk	Medium
H1 — UI Component Duplication	Extract <code>render_stat_card()</code> PHP function to <code>partials/stat-card.php</code> ; replace 4 inline blocks with a <code>foreach</code> loop	Moderate	Medium
H18 — Accessibility Gaps	Replace logout <code><li onclick></code> with <code><button></code> ; add <code>aria-label</code> to icon-only links; replace <code>href="javascript:void(0);\"</code> with semantic button	Moderate	Medium

§3.5 Expected Outcomes

- **Authentication implemented** — `requireAuth()` guard on all protected pages eliminates anonymous access to the admin panel, closing the most critical production blocker before any real data is added.

- **XSS exposure eliminated** — wrapping all five unescaped echo outputs with `htmlspecialchars()` prevents injection the moment menu items or page titles are sourced from user input or a database.
- **Supply-chain risk mitigated** — adding SRI `integrity` attributes to all 9 CDN resources ensures a compromised CDN cannot silently inject malicious scripts into admin sessions.
- **Maintainability improved** — splitting `header.php` into `partials/navbar.php`, `partials/sidebar.php`, and `lib/menu.php` makes each concern independently editable without side-effects on other parts of the layout.
- **Component reuse enabled** — extracting stat cards and nav partials into a `components/` directory means new dashboard pages can be assembled from tested building blocks rather than copy-pasted HTML.
- **Page load performance improved** — adding `defer` to CDN scripts and `loading=\"lazy\"` to images reduces render-blocking time; removing the duplicate SweetAlert2 load eliminates a redundant ~44KB download.
- **Code quality gated in CI** — `phpcs`, `phpstan`, and ESLint running on every pull request catch regressions before they reach production.
- **Browser target documented** — a `.browserslistrc` gives the team a shared, testable definition of supported browsers, preventing compatibility regressions as the codebase evolves.
{"stop_reason":"end_turn","session_id":"","2f0751d9-1410-4e3a-83cd-67e6c2fadaa8","total_cost_usd":1.2305101999999999,"usage":{"input_tokens":17,"cache_creation_input_tokens":69248,"cache_read_input_tokens":828884,"output_tokens":37042,"server_tool_use":{"web_search_requests":0,"web_fetch_requests":0},"service_tier":"standard","cache_creation":{"ephemeral_1h_input_tokens":69248,"ephemeral_5m_input_tokens":0},"inference_geo":"not_available","iterations":{"input_tokens":1,"output_tokens":3049,"cache_read_input_tokens":85639,"cache_creation_input_tokens":722,"cache_creation":{"ephemeral_5m_input_tokens":0,"ephemeral_1h_input_tokens":722},"type":"message"},"speed":"standard"},"modelUsage":{"claude-haiku-4-5-20251001":{"inputTokens":10601,"outputTokens":15,"cacheReadInputTokens":0,"cacheCreationInputTokens":0,"webSearchRequests":0,"costUSD":0.010676,"contextWindow":200000,"maxOutputTokens":32000,"sonnet-4-6":{"inputTokens":17,"outputTokens":37042,"cacheReadInputTokens":828884,"cacheCreationInputTokens":69248,"webSearchRequests":0,"costUSD":1.2198342,"contextWindow":200000,"maxOutputTokens":32000,"terminal_reason":"completed","fast_mode_state":"off","uuid":"fdeba9ab-b1ac-4f6d-bead-29f3d32bbbc6"}}

4. Backend Modernization Analysis

EXECUTIVE SUMMARY

This repository is a minimal PHP admin panel dashboard template consisting of four PHP files (`header.php`, `footer.php`, `index.php`, `profile.php`) with no database, no dependency manager (Composer), and no framework — navigation configuration, breadcrumb resolution logic, and HTML rendering are all co-located inside `header.php`. The overall backend health is **High Risk**: every page is publicly accessible with no authentication or session protection, no security middleware is configured (no rate limiting, no security headers, no CORS policy), multiple unescaped output points establish dangerous patterns for any real-world extension, no linter or CI pipeline is present, and the flat PHP-include architecture has zero separation between presentation and logic layers. No API surface exists, so API governance hotspots (H6–H7) are not applicable. While the codebase’s hardcoded-only data limits immediate exploitability, the structural gaps mean any extension toward real admin functionality will immediately inherit critical security and maintainability debt.

\$4.1 Benchmark Ratings Summary

#	Hotspot	Primary KPI	Good	Moderate	High Risk	Measured	Rating
H1	Dynamic Variable Creation	Dynamic-var-from-input occurrences	0	1–10	>10	0	Good
H2	Global Mutable State	Globals / mutable static state	0	1–5	>5	0	Good
H3	Direct SQL Outside Data Layer	Data-layer compliance %	>90%	60–90%	<60%	N/A — no database	Good
H4	Static / Singleton Abuse	Business-logic static/singleton classes	0	1–5	>5	0	Good
H5	Missing Service Layer	Handlers with inline business logic	<10	10–20	>20	1	Good
H6	API Sprawl	Documented & governed endpoints %	>90%	80–90%	<80%	N/A — no API surface	Good
H7	Missing API Governance	Governance compliance %	100%	90–99%	<90%	N/A — no API surface	Good
H8	Weak Application Architecture	Modules following declared architecture %	>80%	50–80%	<50%	0% — flat PHP include model	High Risk
H9	Missing Module Inventory	Circular dependency count	0	1–3	>3	0	Good
H10	Database Schema Weakness	FK indexes % + migrations with rollback %	Both >90%	One <90%	Both <90%	N/A — no database	Good
H11	Middleware Weakness	Required middleware present + ordered %	100%	80–99%	<80%	0% — no middleware	High Risk

H12	Auth & Authorization Weakness	Protected routes guarded % + hashing algo	100% + bcrypt/argon2	One gap	Both bad	0% guarded, no hashing	High Risk
H13	Backend Security Vulnerabilities	Injection + hardcoded secrets count	0 each	1–3 total	>3 total	5 unescaped outputs ; 0 hardcoded secrets	High Risk
H14	Performance & Caching Gaps	N+1 patterns found	0	1–5	>5	0 — no database	Good
H15	Outdated & Vulnerable Dependencies	Critical/High CVEs found	0	1–3	>3	0 (CDN versions current)	Good
H16	Secrets & Configuration in Source	Hardcoded secrets / .env committed	0	1–2	>2	0	Good
H17	Backend Code Quality	Linters in CI + max cyclomatic complexity	Both good	One gap	Both bad	No linter; no CI	High Risk
H18	Missing SRI — CDN (additional)	CDN resources with integrity %	100%	1–6 missing	All missing	0 of 7 have SRI	High Risk

§4.4 Actions Required

Hotspot	Action	Rating	Priority
H8 — Weak Application Architecture	Introduce <code>src/Controllers/</code> , <code>src/Services/</code> , <code>src/Config/</code> ; implement front-controller pattern; move <code>\$menuItems</code> to Config layer and navigation resolver to <code>NavigationService</code>	High Risk	Critical
H11 — Middleware Weakness	Add <code>session_start()</code> + auth guard in bootstrap; emit <code>X-Frame-Options</code> , <code>X-Content-Type-Options</code> , CSP headers; create server-side <code>/logout.php</code> with <code>session_destroy()</code>	High Risk	Critical
H12 — Auth & Authorization Weakness	Create <code>login.php</code> with <code>password_hash(PASSWORD_BCRYPT)</code> ; add <code>\$_SESSION['authenticated']</code> guard to every page; implement server-side session destruction on logout	High Risk	Critical
H13 — Backend Security Vulnerabilities	Wrap all bare <code><?= \$var ?></code> in <code>header.php</code> with <code>htmlspecialchars(\$var, ENT_QUOTES, 'UTF-8')</code> ; adopt Twig or a custom <code>e()</code> auto-escape helper	High Risk	High
H17 — Backend Code Quality	Add <code>composer.json</code> with PHPStan + PHPCS dev deps; add GitHub Actions CI workflow; extract navigation resolver into a testable class	High Risk	High
H18 — Missing SRI on CDN Resources	Add <code>integrity=\“sha384-...\“</code> <code>crossorigin=\“anonymous\“</code> to all 7 external CDN tags in <code>header.php</code> ; consider vendoring assets locally	High Risk	High

§4.5 Expected Outcomes

- Eliminated OWASP A01 (Broken Access Control):** Session-based auth guards ensure no admin page is publicly accessible — the most critical risk reduction for any real extension of this template.
- XSS risk removed at the source:** Consistent `htmlspecialchars()` wrapping prevents future user-controlled data from becoming a stored XSS vector across all navigation and breadcrumb outputs.
- Supply-chain compromise defence:** SRI hashes let browsers reject tampered CDN scripts/styles before execution — a browser-native safeguard requiring zero server-side complexity.
- Maintainable, testable architecture:** Controller / Service / Config separation means features are added without touching the layout file, and the navigation resolver gains unit-test coverage.
- Automated quality gate:** PHPStan + PHPCS in GitHub Actions catches unescaped output and undefined variables on every pull request, preventing the current no-feedback pattern from persisting.
- Server-side logout integrity:** PHP `session_destroy()` in `/logout.php` ensures the session is actually invalidated regardless of JavaScript state.
- Foundation ready for a real data layer:** A layered architecture allows PDO with parameterized queries to be introduced in a Repository without touching page files — preventing SQL injection by construction before it can be written.:{"stop_reason":"end_turn","session_id":"52f920a3-2133-4606-a93f-dd50395fe046","total_cost_usd":1.0379264000000001,"usage":{"input_tokens":14,"cache_creation_input_tokens":62176,"cache_read_input_tokens":637778,"output_tokens":30847,"server_tool_use":{"web_search_requests":0,"web_fetch_requests":0},"service_tier":"standard","cache_creation":{"ephemeral_1h_input_tokens":62176,"ephemeral_5m_input_tokens":0},"inference_geo":{"not_available"},"iterations":[{"input_tokens":1,"output_tokens":2363,"cache_read_input_tokens":78495,"cache_creation_input_tokens":794,"cache_creation":{"ephemeral_5m_input_tokens":0,"ephemeral_1h_input_tokens":794},"type":"message"}],"speed":"standard"},"modelUsage":{"claude-haiku-4-5-20251001":{"inputTokens":10725,"outputTokens":13,"cacheReadInputTokens":0,"cacheCreationInputTokens":0,"webSearchRequests":0,"costUSD":0.010790000000000001,"contextWindow":200000,"maxOutputTokens":4096},"claude-opus-4-5-20251001":{"inputTokens":14,"outputTokens":30847,"cacheReadInputTokens":637778,"cacheCreationInputTokens":62176,"webSearchRequests":0,"costUSD":1.0271364,"contextWindow":200000,"maxOutputTokens":4096,"terminal_reason":"completed","fast_mode_state":"off","uuid":"59172d0a-ae46-4355-9d09-44e9317a67ec"}}